User-Agent

El User-Agent es una cabecera HTTP estándar que un cliente envía a un servidor web en cada petición. Funciona como una "tarjeta de presentación" o identificador textual.

Una cadena típica de un navegador moderno tiene este aspecto:

Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/124.0.0.0 Safari/537.36

En ella se detalla el motor de renderizado, el navegador específico, la versión y el sistema operativo del cliente.

¿Qué se puede hacer con el User-Agent a grandes rasgos?

Al ser un campo totalmente personalizable y controlado por el cliente, trata distintos puntos:

- Negociación de Contenido y Adaptación de Interfaz:

Los servidores leen el User-Agent para saber si el visitante entra desde un móvil, una tablet o un ordenador de escritorio, adaptando la resolución, el diseño responsivo o sirviendo la versión móvil/escritorio correspondiente.

- Evasión de Controles y WAFs:

En auditorías o ataques, las herramientas de escaneo automatizado dejan su propio nombre en la cabecera. Los cortafuegos web bloquean estas firmas de inmediato. Los atacantes modifican el User-Agent para imitar a un navegador común o a un rastreador legítimo pasar desapercibidos.

- Inyección de Vulnerabilidades y Explotación:

Como los servidores registran el User-Agent en sus ficheros de log o bases de datos de auditoría, se utiliza a menudo como vector para inyectar cargas maliciosas.

- Fingerprinting y Análisis de Trastorno de Bots:

Los equipos de seguridad (Blue Teams) analizan anomalías cruzando el User-Agent declarado con la huella criptográfica de red real. Si un cliente afirma ser un navegador moderno, pero se conecta como un script de consola, es identificado y bloqueado automáticamente como bot malicioso.

Referencias

https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/User-Agent

https://datatracker.ietf.org/doc/html/rfc9110#section-10.1.5

https://owasp.org/projects/secure-headers-project